

Access controls worksheet

	Note(s)	Issue(s)	Recommendation(s)
Authorization /authentication	Objective: List 1-2 pieces of information that can help identify the threat: - The system logs show that the suspicious activity originated from IP address 152.207.255.255, which belongs to his account (rt.jr@erems.net). Although his contract ended on December 27, 2019, his credentials remained active with full administrative privileges - On October 3, 2023, an unauthorized payroll modification was executed by an expired	Objective: Based on your notes, list 1-2 authorization issues: - The user had Full Admin (administrative) authorization privileges. Every employee in the log roster, including Robert Taylor Jr., was configured with full Admin access. - No, their account should not be active. Robert Taylor Jr. was a contractor whose end date was December 27, 2019. Because his contract expired years before this event	Objective: Make at least 1 recommendation that could prevent this kind of incident: Technical Controls Implement Role-Based Access Control (RBAC) & Multi-Factor Authentication (MFA): Restrict system privileges using least privilege principles so that standard roles, contractors, and external vendors do not hold global Admin authorization. Mandate MFA for all administrative log-ins and sensitive payroll functions to block

	contractor account (Legal\Administrator) originating from the host Up2-NoGud • The device used was named Up2-NoGud	occurred on October 3, 2023, his account and administrative permissions should have been revoked immediately upon his departure. Leaving expired contractor accounts active creates a major security vulnerability.	unauthorized access, even if credentials are compromised. • Network Access Control (NAC) & Endpoint Security: Deploy NAC and automated intrusion detection rules to detect, block, and flag unauthorized or rogue hostnames (such as Up2-NoGud) attempting to connect to internal services. Operational Controls • Automated Offboarding Workflows & Access Reviews: Establish an automated offboarding process integrated with HR management systems to disable user credentials and revoke access immediately upon reaching a contract's specified End date. Conduct
--	--	--	--

			<i>monthly account audits to identify and purge stale or over-privileged profiles.</i> Managerial Controls • Separation of Duties (SoD) Policy: <i>Enforce a formal governance policy requiring multi-party approval (dual-authorization) for high-impact actions, such as modifying employee payroll banking details (FAUX_BANK).</i> • Vendor & Third-Party Risk Management Policy: <i>Mandate formal policy frameworks that dictate strict access controls, short-term contract lifecycles, and mandatory notification requirements between legal, HR, and IT departments upon project completion.</i>
--	--	--	--